

ONGARDE · ARCHITECTURE

Architecture Web pour ONG

Infrastructure sécurisée open-source — Site de Lyon

Organisation : ONGarde.org — ONG française

Site : Lyon (192.168.1.0/24)

Version : 2.0 (actualisée) · **Date :** 23/06/2026

Auteur : Jean Dovy — Infrastructure Web Lead

Équipe : Muriel Has · Valentina Masiello · Franck Rouane

CLASSIFICATION : INTERNE

ONGarde.org
Projet final — Jedha Bootcamp

Sommaire

• 1.	Vue d'ensemble	3
• 2.	Architecture générale	3
• 3.	Composants techniques	3
• 4.	Topologie & adressage IP	4
• 5.	Sécurité et firewall	5
• 6.	Intégration Wazuh (SIEM)	5
• 7.	Cas d'usage ONGarde	6
• 8.	Checklist de mise en place	7
• 9.	Conclusion	7

Note de version (2.0) : ce document de design (Phase 1, v1.0) a été aligné sur l'infrastructure réellement déployée — plan d'adressage **192.168.1.0/24** (et non 192.168.10.0/24), serveur web en **10.0.0.1** avec HTTPS auto-signé, supervision Wazuh via Indexer + Dashboard. Les volets Marseille et WireGuard restent hors scope final.

1 Vue d'ensemble

ONGarde.org est une ONG numérisée dont l'infrastructure répond à cinq priorités : budget maîtrisé, confidentialité, collaboration interne, conformité et résilience.

- **Budget bas** → stack 100% open-source.
- **Confiance & confidentialité** → chiffrement, authentification centralisée.
- **Collaboration interne** → partage de fichiers sécurisé.
- **Conformité** → journalisation et supervision exhaustives.
- **Résilience** → sauvegarde automatisée.

Aspect	Détail
Organisation	ONGarde.org — ONG française
Utilisateurs	20 à 50 membres du staff
Localisation	Lyon (siège) — déployé. Marseille (antenne) : hors scope final.
Disponibilité requise	99% (quelques heures de maintenance acceptées)
Données sensibles	Listes donateurs, budgets, communications
Conformité	RGPD (données UE), confidentialité associative

2 Architecture générale

Stack technologique — Site de Lyon (déployé)

- **Serveur web** : Nginx (reverse proxy, web public, HTTPS).
- **Base de données** : PostgreSQL.
- **Partage de fichiers** : Nextcloud (collaboration + calendriers).
- **Authentification** : Samba AD (SSO centralisé).
- **Supervision** : Wazuh (SIEM + monitoring sécurité) — retenu plutôt que Zabbix.
- **Pare-feu** : cluster pfSense HA (CARP/PFSYNC) + UFW par VM.

Hors scope final : le site de Marseille (réplica Nextcloud, RODC Samba, agent Wazuh, tunnel WireGuard) faisait partie du design initial mais n'a pas été déployé. Il est conservé comme piste post-bootcamp.

3 Composants techniques

VM	Service	IP	CPU / RAM / Disque	Ports
lyon-web	Nginx (web + reverse proxy)	10.0.0.1	2c / 4 Go / 50 Go	80 / 443
lyon-db	PostgreSQL	192.168.1.20	2c / 8 Go / 100 Go	5432

VM	Service	IP	CPU / RAM / Disque	Ports
lyon-nextcloud	Nextcloud (fichiers + collab)	192.168.1.30	2c / 8 Go / 500 Go	443
lyon-dc	Samba AD (ongarde.local)	192.168.1.40	2c / 4 Go / 50 Go	389 / 445
lyon-wazuh	Wazuh (SIEM + IDS)	192.168.1.50	4c / 8-12 Go / 200 Go	1514 / 1515 / 443

Rôles clés

- **Nginx (lyon-web)** : serveur web public, reverse proxy vers Nextcloud, terminaison SSL/TLS (certificat auto-signé — lab GNS3, domaine fictif `ongarde.local` / 10.0.0.1), logs vers Wazuh.
- **PostgreSQL (lyon-db)** : contacts/donateurs, historique financier, backend Nextcloud, sauvegarde quotidienne (02:00) + nettoyage 30 jours.
- **Nextcloud (lyon-nextcloud)** : partage de documents confidentiels, calendriers, versioning 30 jours, SSO LDAP (Samba AD).
- **Samba AD (lyon-dc)** : SSO, gestion des groupes (Staff, Finance, Logistique), logs d'audit.
- **Wazuh (lyon-wazuh)** : détection (bruteforce, modification de fichiers sensibles, escalade de privilèges, requêtes BD suspectes, certificats expirant, disque > 80%, accès aux partages sensibles).

Choix Wazuh vs Zabbix : Zabbix supervise la performance (CPU, RAM, disque) ; Wazuh est un SIEM de sécurité (logs, alertes de menaces, conformité). Pour ONGarde — audit trail exhaustif et détection de menaces — Wazuh est plus adapté.

4 Topologie & adressage IP

VM	Service	IP	État
lyon-web	Nginx (HTTPS)	10.0.0.1	Déployé
lyon-db	PostgreSQL	192.168.1.20	Déployé
lyon-nextcloud	Nextcloud	192.168.1.30	Déployé
lyon-dc	Samba AD	192.168.1.40	Déployé
lyon-wazuh	Wazuh SIEM	192.168.1.50	Déployé
marseille-rodC	Samba RODC	192.168.2.x	Hors scope
marseille-nextcloud	Nextcloud Sync	192.168.2.x	Hors scope

Correction d'adressage : le plan initial (192.168.10.0/24) a été remplacé par le plan réellement déployé **192.168.1.0/24**. Le serveur web fait exception : il est sur **10.0.0.1** (interface ens4), un /24 distinct — le routage vers les services internes et le Wazuh Manager (192.168.1.50) transite par le cluster pfSense. La passerelle/VIP CARP est 192.168.1.3.

LYON (192.168.1.0/24) – DÉPLOYÉ

- └ Cloud / NAT → Internet (simulation GNS3)
- └ pfSense HA – VIP CARP 192.168.1.3
 - └ lyon-web 10.0.0.1 (HTTPS, /24 distinct via pfSense)

```
└─ lyon-db          192.168.1.20
└─ lyon-nextcloud  192.168.1.30
└─ lyon-dc         192.168.1.40
└─ lyon-wazuh      192.168.1.50
```

MARSEILLE — HORS SCOPE FINAL (non réalisé)

· RODC Samba · réplique Nextcloud · agent Wazuh · WireGuard

5 Sécurité et firewall

Principes de défense en profondeur

- **Moindre privilège** : chaque VM n'ouvre que les ports strictement nécessaires.
- **Chiffrement en transit** : SSL/TLS + clés SSH (pas de mots de passe).
- **Authentification centralisée** : Samba AD (SSO).
- **Supervision exhaustive** : Wazuh observe chaque action.
- **Fail-safe** : UFW en DENY par défaut, whitelist explicite ; pare-feu pfSense en frontal.

Exemple UFW — lyon-web

```
sudo ufw default deny incoming
sudo ufw default allow outgoing
sudo ufw allow 22/tcp           # SSH admin
sudo ufw allow 80/tcp          # HTTP
sudo ufw allow 443/tcp         # HTTPS
sudo ufw allow out 192.168.1.20 port 5432 # PostgreSQL
sudo ufw allow out 192.168.1.40 port 389  # Samba LDAP
sudo ufw allow out 192.168.1.50 port 1514 # Wazuh logs
sudo ufw enable
```

Rappel routage : lyon-web étant sur 10.0.0.0/24, les flux sortants vers .20/.40/.50 (LAN 192.168.1.0/24) passent par pfSense — vérifier les règles correspondantes côté cluster.

6 Intégration Wazuh (SIEM)

Manager (lyon-wazuh)

Déploiement de la pile Wazuh 4.x : Manager + Indexer + Dashboard (architecture OpenSearch, sans Elasticsearch/Kibana).

```
# Installation assistée (script officiel Wazuh 4.x)
curl -s0 https://packages.wazuh.com/4.x/wazuh-install.sh
sudo bash ./wazuh-install.sh -a # manager + indexer + dashboard
systemctl enable --now wazuh-manager wazuh-indexer wazuh-dashboard
```

Agents (autres VMs)

```
# Sur lyon-web, lyon-db, lyon-nextcloud, lyon-dc
apt install wazuh-agent
sed -i 's/MANAGER_IP/192.168.1.50/' /var/ossec/etc/ossec.conf
systemctl enable --now wazuh-agent
```

Règles de détection clés (exemples)

```
<!-- Bruteforce SSH -->
<rule id="100001" level="7">
  <if_sid>5710</if_sid>
  <frequency>5</frequency> <timeframe>360</timeframe>
  <description>SSH Brute Force Attack</description>
</rule>

<!-- Accès dossier sensible Nextcloud -->
<rule id="100003" level="6">
  <match>/finance|/budget|/donor</match>
  <description>Sensitive folder accessed</description>
</rule>

<!-- Fichiers système critiques -->
<rule id="100004" level="9">
  <match>/etc/passwd|/etc/shadow|/root/.ssh</match>
  <description>CRITICAL: System files modified</description>
</rule>
```

Tableau de bord : <https://192.168.1.50> — alertes critiques (24h), avertissements, statistiques (events, agents, conformité), audit trail (qui, quand, quoi).

7 Cas d'usage ONGarde

Scénario 1 — Nouvel employé (Alice)

1. Admin crée le compte Samba AD : `samba-tool user create alice`
2. Alice se connecte à Nextcloud → auth LDAP automatique
→ accès `/shared/staff`, sync desktop
3. Wazuh enregistre : new AD account · first Nextcloud login · sync initiated

Scénario 2 — Incident : tentative d'injection SQL

```
15:10 Wazuh : "SQL ERROR: syntax error" - 50 erreurs en 5 min → ANORMAL
      Source : lyon-web (10.0.0.1)
Actions : incident #2847 créé · email admin · blocage IP source (pfSense)
          backup valide (restore possible) · rapport PDF généré
```

Scénario 3 — Sauvegarde & réplication

Chaque nuit (02:00) :

1. PostgreSQL : `pg_dump → ong_db_YYYYMMDD.sql`
2. Nextcloud : `rsync` des données (sauvegarde externe)
3. Wazuh : bande passante utilisée, erreurs (timeout, espace disque)

Note : la réplication vers Marseille (RODC, rsync inter-sites) figurait au design initial mais n'est pas en service — sauvegardes conservées en local/externe.

8 Checklist de mise en place

Phase	Élément	État
Infrastructure	GNS3 + VMs créées, IPs statiques (192.168.1.0/24)	Déployé
	lyon-web : Nginx + HTTPS (cert auto-signé, 10.0.0.1)	Déployé
	lyon-db : PostgreSQL · lyon-nextcloud : Nextcloud	Déployé
	lyon-dc : Samba AD (ongarde.local) · SSH par clé	Déployé
Intégration	Wazuh Manager + Indexer + Dashboard	Déployé
	Agents Wazuh sur les VMs Lyon	Déployé
	Nextcloud LDAP (Samba AD) · reverse proxy Nginx · backup cron	Déployé
Multi-site	WireGuard (Lyon/Marseille) · RODC · rsync inter-sites	Hors scope
	Tunnel VPN testé · agents Marseille	Hors scope
Sécurité	Audit par un autre groupe (pentest)	En cours
	Scans nmap · tests injection/bruteforce · rapport pentest	En cours
Présentation	Diagrammes · doc firewall · procédures backup · slides démo	En cours

9 Conclusion

L'infrastructure de Lyon respecte les contraintes de l'ONG : stack 100% open-source, confidentialité (SSO AD + TLS + audit Wazuh), collaboration (Nextcloud), résilience (sauvegardes quotidiennes) et conformité (SIEM Wazuh).

Points critiques à valider

- **RAM lyon-wazuh** : minimum 8 Go (Indexer gourmand).

- **Certificat SSL** : auto-signé (domaine fictif / lab GNS3), pas de Let's Encrypt.
- **Fail2ban** : à installer sur chaque VM (protection bruteforce).
- **Failover pfSense** : test de bascule CARP complet (validation restante).

Extensibilité future (hors scope)

Multi-site Marseille + WireGuard, Prometheus/Grafana (métriques), Ansible (automation), stockage objet S3-compatible.